

ACTIVIDAD 1

ANALISIS Y PLANIFICACIÓN DEL PENTEST

Vanessa Valderrama Gutierrez

Hacker Women Council – Ethical Hacking

OBJETIVOS DEL PENTEST.

1. Entender los riesgos reales a los que se enfrenta la Aurora Market.
2. Revisar y analizar la página web.
3. Entregar información clara y útil para corregir errores y tomar mejores decisiones de seguridad.

ALCANCE.

- Si se evaluará (sistemas o elementos incluidos en el alcance):
 - Interfaz de la página web de la tienda.
 - Sistema interno de la página.
- Fuera del alcance (elementos que no serán evaluados):
 - Redes sociales de la empresa.
 - Equipos personales de los empleados.
 - Correos electrónicos del personal.
 - Proveedores externos.

AUTORIZACIÓN Y CONDICIONES.

- Permisos requeridos:
 - Documentos legales donde Aurora Market autorice las pruebas pertinentes.
 - Acuerdos de confidencialidad para cuidar y no revelar información privada.

- Condiciones acordadas:
 - No interrumpir deliberadamente el funcionamiento de la plataforma.
 - No afectar información real de los clientes.
 - Realizar las pruebas durante horarios de menor actividad.
 - Documentación detallada.

TIPO DE PENTEST.

GRAY-BOX

Aurora Market no entrego toda la información técnica ni el código interno de la página web. Sin embargo, si dio cierta información básica; el funcionamiento de la aplicación web, la existencia de una base de datos y los diferentes tipos de usuarios (clientes y administradores). Teniendo esta información parcial se puede simular ser un cliente promedio, navegar dentro de estos entornos para posteriormente, descubrir posibles áreas de mejora.

PLANIFICACIÓN.

- Objetivos:
Definir qué queremos encontrar. En este caso, posibles vulnerabilidades a la seguridad y confidencialidad de los datos.
- Alcance:
Dejar en claro que solamente se consultará la pagina web.
- Permisos y condiciones:
Firmar las autorizaciones, acuerdos de confidencialidad para fijar las respectivas reglas.
- Metodología a utilizar:
Se utilizará la metodología OWASP.
- Recopilación de información previa:
Conseguir la dirección web y creación de cuentas para realizar pruebas.
- Recursos necesarios:
Preparar los programas de evaluación y equipos físicos que se usará.
- Programación del pentest:
Fijar el calendario con las horas de prueba y la fecha de entrega de los resultados. Por requerimiento de Aurora Market las pruebas se realizarán en horarios con menor afluencia, en este caso, de noche.

FASE DEL PENTEST.

- Reconocimiento:
Mirar la página desde afuera como un visitante común para entender cómo está construida y qué herramientas se utilizan.
- Análisis de vulnerabilidades:
Buscar posibles "puertas abiertas" o descuidos en los formularios, registros y carritos de compra.
- Explotación:
Intentar, cuidadosamente, entrar por esas puertas abiertas usando cuentas de prueba, demostrando que el error existe sin romper nada.
- Post-explotación:
Ver qué tan lejos podría llegar un atacante real una vez dentro como a la información a la que podría acceder o los privilegios podría obtener, pero cuidando no dañar información real.
- Informe:
Escribir un documento final que resuma las fallas encontradas y explique cómo solucionarlas.

INVESTIGACIÓN.

Metodología elegida: OWASP WSTG (Guía de Pruebas de Seguridad para Aplicaciones Web).

¿Por qué?

Es una guía creada por expertos de todo el mundo que funciona como una lista de revisión especializada únicamente en tiendas y páginas web. Es muy útil porque va directo al problema de Aurora Market: enseña a revisar que ningún cliente pueda entrar a cuentas ajenas ni ver compras de otras personas cambiando datos en el navegador. Se aplica simulando compras y accesos como un usuario normal para verificar que los pedidos, los pagos y el panel de los empleados estén bien protegidos y separados.